

Security Assessment Report

Windows Server Active Directory Lab Environment (Lab-DC01)

Prepared by: Alexander Juan Gantt

Assessment basis: NIST SP 800-53 Rev. 5 (Moderate baseline control selection)

Assessment type: Self-directed technical security assessment, independent home lab

Environment: Locally hosted VirtualBox VM, Windows Server evaluation build, isolated lab network (no production or government data, systems, or networks)

Note on Origin

This report documents a security assessment performed against a self-built home lab environment as part of independent GRC/compliance skill development. It is not a work product of, and contains no information from, any government agency, employer, or classified/controlled system. Reporting generated during prior military service resided on government information systems to which access does not persist after separation and cannot be reproduced or disclosed here. This document is offered as a demonstration of assessment methodology, structure, and reporting format equivalent to those used in formal state/federal security assessments.

1. Executive Summary

A self-directed security assessment was performed against a lab Active Directory domain controller and supporting Windows Server host to evaluate control implementation against the NIST SP 800-53 Rev. 5 Moderate baseline. The assessment identified five findings across account management, audit logging, authenticator management, configuration management, and boundary protection control families. Four findings were remediated within the lab environment; one remains open and is tracked as a Plan of Action and Milestones (POA&M) item below.

2. Scope and Methodology

- System assessed: Single-domain Active Directory environment (Lab-DC01), Windows Server, hosted locally via VirtualBox
- Control baseline: NIST SP 800-53 Rev. 5, Moderate impact baseline (subset relevant to a single-host AD environment)
- Method: Manual configuration review, Windows Security/Group Policy audit, local vulnerability scan, and host firewall rule review
- Tools used: Windows Event Viewer, Local Security Policy/Group Policy Editor, Nessus (lab scan), native Windows firewall configuration
- Limitations: Single-host lab scope; no network segmentation, no external/production traffic, no live user population

3. Findings

Finding ID	Control(s)	Description	Risk Rating	Status
F-01	AC-2, AC-6 (Account Mgmt, Least Privilege)	Two lab domain accounts retained Domain Admin rights with no documented business justification.	Moderate	Remediated

Finding ID	Control(s)	Description	Risk Rating	Status
F-02	AU-2, AU-6 (Audit Events, Review/Analysis)	Windows Security audit policy did not capture logon/logoff events on the domain controller.	Moderate	Remediated
F-03	IA-5 (Authenticator Management)	Default local administrator password policy did not enforce complexity or expiration.	High	Remediated
F-04	CM-6, CM-7 (Config Settings, Least Functionality)	SMBv1 and unused legacy services remained enabled on the baseline server image.	Moderate	Remediated
F-05	SC-7 (Boundary Protection)	Host-based firewall rules did not restrict inbound RDP to an approved management subnet.	High	Open — POA&M item

4. Plan of Action and Milestones (POA&M)

POA&M ID	Weakness	Source	Milestone	Scheduled Completion	Status
P-01	RDP exposed beyond approved management subnet (F-05)	Self-assessment	Restrict inbound RDP via host firewall rule + document approved subnet	30 days from assessment date	In progress

5. Conclusion

This assessment reflects a full control-selection-to-remediation cycle consistent with NIST SP 800-53-based assessment methodology: control review, finding documentation, risk rating, remediation, and POA&M tracking for the one item not fully closed within the lab environment. It is provided as a sanitized, non-privileged demonstration of assessment and reporting approach in lieu of prior government reporting, which cannot be shared per the note on page 1.